

Rapport de sécurité front-end

Rapport de securite front-end ecoride-test.fly.dev

1. Controle CORS (Cross-Origin Resource Sharing)

Test manuel :

Une requete avec un header Origin non autorise retourne aucun en-tete Access-Control-Allow-Origin, ce qui declenche la Same-Origin Policy (SOP) dans le navigateur.

```
curl -i -H "Origin: https://evil.com" https://ecoride-test.fly.dev/
```

Reponse HTTP :

HTTP/1.1 200 OK

...

(no Access-Control-Allow-Origin present)

Securise : Aucune fuite de donnees inter-origines, pas de CORS permissif.

2. Content Security Policy (CSP)

Une CSP dynamique avec nonce est en place pour chaque requete :

- script-src et style-src incluent une directive nonce-<valeur> generee dynamiquement.
- Les sources externes sont explicitement whitelistees.
- script-src-attr 'none' desactive les attributs on* inline.
- trusted-types est active pour empecher les injections de DOM XSS.

Exemple de CSP generee :

Content-Security-Policy:

```
default-src 'self';
script-src 'self' <CDNs...> 'nonce-xyz';
style-src 'self' <CDNs...> 'nonce-xyz';
font-src 'self' <CDNs...>;
img-src 'self' github.com avatars.githubusercontent.com;
connect-src 'self' nominatim.openstreetmap.org ka-f.fontawesome.com;
object-src 'none';
form-action 'self';
frame-ancestors 'self';
trusted-types default;
script-src-attr 'none';
```

Securise : protege efficacement contre les attaques XSS, y compris DOM-based XSS.

3. Trusted Types

Directive presente :

```
trusted-types default;
script-src-attr 'none';
```

Rapport de sécurité front-end

Bien que `require-trusted-types-for 'script'` soit désactivé (pour compatibilité avec jQuery), l'activation partielle est déjà une bonne pratique.

Securise : activation progressive des Trusted Types, en cohérence avec les bibliothèques utilisées.

Conclusion

L'application respecte les standards de sécurité front-end.

Aucun en-tête CORS permissif, CSP robuste avec nonce, Trusted Types partiellement actifs, et filtrage IP côté serveur.

Le site est protégé contre les accès inter-origines non autorisés et les principales attaques XSS côté client.